2025 年上海市高等学校信息技术水平考试试卷

四级 网络与信息安全（A 场）

（本试卷考试时间 150 分钟）

一、单选题（ 本大题 20 道小题 ，每小题 1 分，共 20 分），从下面题目给出的 A、B、C、D 四个可供选择的答案中选择一个正确答案。

1.开展数据处理活动的组织、个人不履行《中华人民共和国数据安全法》第二十七条、第二十九条、第三十条规定的数据安全保护义务的，由有关主管部门责令改正，给予警告，可以并处五万元以上五十万元以下罚款，对直接负责的主管人员和其他直接责任人员可以处（）罚款。

A.一万元以上十万元以下

B.一万元以上五万元以下

C.一千元以上一万元以下

D.五万元以上十万元以下

2.《中华人民共和国密码法》规定，密码管理部门依法对密码工作机构的（）工作进行指导、监督和检查，密码工作机构应当配合。

A.核心密码、普通密码

B.核心密码、关键密码

C.重要密码、关键密码

D.重要密码、普通密码

3.一个完整的密码体制，不包括以下（）要素。

A.数字签名

B.密文空间

C.明文空间

D.密钥空间

4.一次一密(One-Time-Pad，OTP)是一种理想的加密方案，下列关于一次一密的描述中，错误的是（）。

A.应用较广泛

B.运算效率高

C.密钥共享难

D.无条件安全

5.目前非对称密码算法主要用于保护对称体制下密钥的安全性，或用来进行数字签名，而非直接用于数据文件加密，主要因为（）。

A.公钥密码的效率比较低

B.公钥密码的密钥太短

C.公钥密码的安全性不高

D.公钥密码抗攻击性比较差

6.王小云院士破解了 MD5 和 SHA1 哈希函数，参与设计了（）商密算法。

上海市教育考试院 版权所有

A. SM3
B. SM2
C. SM1
D. SM4

7. 1982 年，姚期智提出了经典密码学案例——百万富翁问题，即在没有可信第三方参与的情况下，两位不愿透露具体财富数额的富翁比较谁更富有。该问题本质上是（）的典型应用场景。
A. 安全多方计算
B. 对称加密技术
C. 数字签名技术
D. 哈希函数算法

8. 第三级等级保护对象需具备防护以下（）威胁源的能力。
A. 有组织团体发起、资源较丰富的攻击
B. 小型组织发起、资源有限的攻击
C. 个人发起、资源极少的攻击
D. 国家级敌对组织发起、资源丰富的攻击

9. PGP 加密邮件时采用的常见混合加密模式是（）。
A. 用 AES 加密邮件内容+RSA 加密 AES 密钥
B. 用 RSA 加密邮件内容+ECC 签名
C. 用 SHA-256 哈希邮件内容+ECC 签名哈希值
D. 用量子密钥加密内容+传统算法签名

10. 为保障用户画像分析的准确性，脱敏时需优先保留（）。
A. 统计分布特征
B. 敏感属性
C. 直接标识符
D. 精确地理位置

11. 用户登录 CRM 系统后，保持会话有效的前提下，长时间无操作的风险是（）。
A. 会话劫持
B. 增加网络带宽消耗
C. 降低数据库并发性能
D. 触发防火墙误阻断

12. 在勒索软件检测中，与传统特征码检测技术相比，利用 AI 模型检测的最大突破是（）。
A. 无需更新病毒库即可检测未知变种
B. 完全避免误报
C. 可识别加密文件的熵值突变
D. 降低 CPU 资源占用

13. 在 Windows 操作系统中，关于 Windows 防火墙的管理，以下说法正确的是（）。

上海市教育考试院 版权所有

A.使用 netsh advfirewall 命令可以配置高级防火墙规则
B.只能通过控制面板配置 Windows 防火墙，不能使用命令行工具
C.关闭 Windows 防火墙后，系统会自动阻止所有入站和出站连接
D.Windows 防火墙不支持按端口号进行规则配置

14.以下（）技术可保护数据在网络传输过程中的机密性。
A.VPN 或 TLS 加密通道
B.RAID 5 数据冗余
C.防火墙访问控制列表
D.数据库索引优化

15.在全网行为管理中常用 QoS(服务质量控制)对网络带宽进行智能分配，其主要依赖于（）技术对业务类型进行识别。
A.深度包检测（DPI）
B.端口映射
C.URL 过滤
D.ARP 绑定

16.企业网络中，IPv6 主机通过 SLAAC 获取地址后，无法访问外部 IPv4 网站。导致该问题出现的主要原因是（）。
A.企业网络未部署 NAT64/DNS64 转换服务，无法将 IPv6 主机的 IPv4 请求转换为 IPv6 可路由的格式。
B.SLAAC 配置错误导致 IPv6 地址生成失败，主机无法获得有效 IPv6 地址。
C.主机未手动配置 IPv4 地址，导致无法访问 IPv4 资源。
D.企业网络防火墙阻止了所有 IPv6 流量，但允许 IPv4 通信。

17.属于多因素认证（MFA）的身份认证方式是（）。
A.用户名 + 密码 + 动态验证码（如短信或 App）
B.指纹识别
C.智能卡
D.用户名 + 密码

18.常见的通过 HTTP 头部注入技术进行 SQL 注入的测试方法是（）。
A.在 Referer 中注入 SQL 语句
B.修改 User-Agent 以伪装操作系统
C.清除 Cookie 中的会话标识
D.在 POST body 中注入 JavaScript 代码

19.防御越权漏洞最有效的方法是（）。
A.实施全面的服务器端权限检查
B.仅依赖前端验证
C.使用复杂的验证码
D.限制 API 调用频率

上海市普通高等教育考试院 版权所有

20.可能导致越权漏洞的是（）。
A.系统仅通过隐藏字段判断用户角色
B.使用 HTTPS 传输所有数据
C.对用户输入进行 XSS 过滤
D.实施严格的密码策略

二、多选题（ 本大题 10 道小题 ，每小题 2 分，共 20 分），从下面题目给出的 A、B、C、D 四个可供选择的答案中选择所有正确答案。

1.密码学根据其研究的范围可分为（）。
A.密码编码学
B.密码管理学
C.密码分析学
D.密码工程学

2.安全的密码算法若没有被正确实现，也容易给攻击者留下攻击面。下列（）均属于由于实现不当而导致的攻击。
A.基于时间的侧信道攻击
B.基于能耗的侧信道攻击
C.错误攻击
D.量子攻击

3.根据《中华人民共和国网络安全法》，关键信息基础设施运营者依法需遵守（）。
A.在中国境内运营中收集的个人信息必须境内存储
B.采购可能影响国家安全的网络产品需通过安全审查
C.每年至少进行一次网络安全风险评估
D.设置专门安全管理机构并对负责人进行安全背景审查

4.将 C 类网络 192.168.10.0/24 划分为 4 个等长子网，（）均是有效的子网配置。
A.子网 1：192.168.10.0/26
B.子网 2：192.168.10.64/26
C.子网 3：192.168.10.128/25
D.子网 4：192.168.10.192/26

5.根据《中华人民共和国个人信息保护法》要求，按照泄露或者非法使用个人信息对个人合法权益造成的危害程度，个人信息可分为（）。
A.一般个人信息
B.敏感个人信息
C.特殊个人信息
D.其它个人信息

6.攻击者对抗 AI 威胁检测系统的技术包括（）。
A.生成对抗样本（Adversarial Examples）
B.窃取 AI 模型（Model Stealing）
C.增加恶意软件大小至 1GB 以上

上海市教育考试院 版权所有

D.注入噪声数据污染训练集

7.区块链系统可能面临的安全攻击包括（）。
A.重放攻击
B.智能合约漏洞攻击
C.栈溢出
D.社会工程学攻击

8.在全网行为管理中，流量控制技术常见的实现方式包括（）。
A.P2P 限速
B.应用层带宽限制
C.DNS 劫持
D.分时段限速

9.可能导致文件上传功能出现安全漏洞的行为包括（）。
A.仅通过文件扩展名判断文件类型
B.上传目录具有可执行权限
C.上传路径由用户可控字段拼接生成
D.文件重命名机制使用随机 UUID

10.以下（）均属于业务逻辑漏洞。
A.通过修改订单 ID 查看他人订单
B.重复提交表单导致多次扣款
C.使用 SQL 注入获取数据库信息
D.利用竞态条件无限领取优惠券

三、是非题（ 本大题 10 道小题 ，每小题 1 分，共 10 分）。
1.《中华人民共和国密码法》中所称密码，是指采用特定变换的方法对信息等进行加密保护、安全认证的技术、产品和服务。

2.Diffie-Hellman 密钥协商算法是第一个不需要事先共享秘密就可以在公开信道上建立共享密钥的实用算法。

3.人工智能系统设计、研发、训练、测试、部署、使用、维护的等生命周期各环节都面临安全风险，既面临自身技术缺陷、不足带来的风险，也面临不当使用、滥用甚至恶意利用带来的安全风险。

4.《中华人民共和国个人信息保护法》规定,匿名化处理后无法还原的信息不再受《个人信息保护法》保护。

5.风险评估的第一步是分析系统脆弱性（Vulnerability）。

6.灾难恢复时，应优先恢复业务数据库，再恢复操作系统环境。

上海市教育考试院 版权所有

7.与传统防火墙相比，下一代防火墙无法与目录服务（如 Active Directory）集成进行基于用户的访问控制。

8.网络安全态势感知技术只能用于被动展示现状，无法参与主动防御或自动响应。

9.DOM 型 XSS 是由前端 JavaScript 代码生成的，攻击者无需后端服务器配合即可实现脚本注入。

10.SQL 报错注入攻击的本质是构造导致数据库查询失败的恶意语句，让数据库在解析或执行过程中产生详细的错误信息，并将这些信息返回给前端显示。这种方式的前提是服务器没有屏蔽数据库的详细报错信息，且前端会展示这些报错内容。

四、操作题

（一）、简答题（2题，共10分）

1、在 Web 应用开发过程中，文件处理、系统信息查询等特定功能的实现，往往需要调用服务器系统命令或执行相关代码。但处理这类直接与底层系统交互的操作时，细微的疏漏就可能成为命令执行漏洞的诱因。（共5分）

请回答以下问题：

（1） 命令执行漏洞的形成原因是什么？（2分）

答：_____

（2） 请说明两种防御上述漏洞的有效方法。（3分）

答：_____

2、在信息时代，数据作为核心资产，其安全性直接关乎个人隐私、企业利益乃至国家信息安全。数据在生命周期中呈现静态与动态两种状态，面临的安全威胁各有不同：静态数据主要存储于数据库、硬盘等介质，易遭非法入侵、数据窃取；动态数据则在网络中传输流转，可能面临监听、拦截、篡改等风险。（共5分）

请回答以下问题：

（1） 请简述静态数据与动态数据的主要保护措施分别有哪些？（3分）

答：_____

（2） 在实际应用中，如何判断某一数据需要采用数据保密技术进行保护？（2分）

答：_____

（二）、基础操作题（2题，共30分）

（本类型题目重点考查常见的漏洞类型包括：SQL注入漏洞、XSS（跨站脚本）漏洞、文件上传漏洞、命令执行漏洞、越权漏洞、CSRF（跨站请求伪造）漏洞、XXE（xml实体注入）漏洞、SSRF（服务器端请求伪造）漏洞）

1、文件上传漏洞（共15分，每小题3分）

场景：某招聘网站允许上传PDF版简历文件，但后端仅检查文档的Content-Type。攻击者将shell.php伪装成resume.pdf文件上传，访问该文件能成功执行系统命令。

请回答以下问题：

（1） 网站后端仅检查文档的Content-Type会存在一定安全风险，其存在风险的原因是什

上海市教育考试院 版权所有

么？（3分）

答：_____

（2） 写出两种绕过扩展名黑名单（如禁止上传.php文件）的攻击手法。（3分）

答：_____

（3） 如何利用.htaccess文件实现任意文件执行？（3分）

答：_____

（4） 分别给出针对文件类型、扩展名、内容检测的防御方案。（3分）

答：_____

（5） 若将服务器上php.ini文件中的cgi.fix_pathinfo参数设为1，可能引发哪种漏洞？（3分）

答：_____

2、越权访问漏洞（共15分，每小题3分）

场景：某电商平台订单查看接口URL为/order?user=zhangsan&id=123，该平台系统仅验证用户登录状态，而未进行其他校验。攻击者通过修改id值即可查看其他用户的订单信息，可知该平台系统存在越权漏洞。

请回答以下问题：

（1） 上述漏洞属于水平越权还是垂直越权？（3分）

答：_____

（2） 上述漏洞产生的原因是什么？（3分）

答：_____

（3） 若API返回包含敏感字段（如手机号）的数据，如何通过数据脱敏来降低风险？（3分）

答：_____

（4） 假设用户李四名下有订单号为2025080854321的待支付订单，攻击者想查看该订单信息该输入怎样的url？（3分）

答：_____

（5） RBAC（基于角色的访问控制）能否直接解决上述越权访问漏洞？为什么？（3分）

答：_____

（三）、实践应用题（2题 共30分）

1、在线教育平台安全事件（共15分，每小题3分）

某在线教育平台使用 Linux 操作系统搭建，管理员为图方便，将多个应用程序配置为以 root 权限运行。平台具有课程搜索功能，其后台执行的 SQL 语句为SELECT * FROM courses WHERE course_name = '${search_content}'，有用户在搜索框输入' OR 1=1 --后，查看到了平台所有课程的信息。平台规定只有付费用户才能观看 VIP 课程，但有普通用户发现通过修改 URL 中的参数可直接访问 VIP 课程内容。此外，平台用户密码采用明文存储，

上海市教育考试院 版权所有

且用户的学历信息、职业信息与课程浏览记录为同一安全管理级别。针对以上场景，回答下列问题：

（1） 多个应用程序都在 root 用户权限下运行，违背了什么安全授权原则？（3分）

答：_____

（2） 用户在搜索框输入特殊字符查看到所有课程信息，利用的是哪种漏洞？（3分）

答：_____

（3） 普通用户通过修改 URL 参数访问 VIP 课程，说明系统缺失了访问控制中的哪项核心机制？（3分）

答：_____

（4） 平台将用户密码以明文形式存储，未采用密码学中用于保护密码的不可逆基础技术是什么？（3分）

答：_____

（5） 用户的学历、职业信息与课程浏览记录为同一安全级别管理，不符合数据安全中的哪项要求？（3分）

答：_____

2、钓鱼邮件安全事件（共15分，每小题3分）

某公司的一台文件服务器近期遭到勒索病毒攻击。该服务器运行Windows 10操作系统，并连接至公司内部网络。攻击起始于员工打开钓鱼邮件附件中的恶意RTF文档。该文档利用Microsoft Office CVE-2017-0199漏洞（RTF远程代码执行漏洞），在未授权情况下自动触发恶意宏代码，下载并执行勒索软件载荷。该载荷利用系统漏洞提权至系统管理员权限，随后通过内网SMB协议漏洞横向移动，在未启用防火墙网络隔离的环境中扩散至多个部门。因未实施定期备份策略，导致核心数据被加密且无法恢复。病毒使用AES-256算法加密服务器上的所有文档、图片和数据库文件，并将文件扩展名改为“.linl2”。攻击者在加密完成后显示勒索信息，要求支付0.5比特币以换取解密密钥。针对以上场景，回答下列问题：

(1) 勒索病毒最初是如何进入系统的？（3分）

答：_____

(2) 勒索病毒为什么要先提权，再横向传播？（3分）

答：_____

(3) 本案例中勒索病毒程序采用了AES-256算法，其核心目的是什么？（3分）

答：_____

(4) 本案例中勒索病毒得以横向扩散，是什么原因造成的？（3分）

答：_____

(5) 如何有效防止数据永久丢失？（3分）

答：_____

上海市教育考试院 版权所有

（四）、场景设计与行业应用（共30分，每小题3分）

某高校整体网络安全设计方案

一、建设背景

2016年4月19日，习近平总书记在北京主持召开网络安全和信息化工作座谈会并发表重要讲话，并明确指出：“网络安全和信息化是相辅相成的。安全是发展的前提，发展是安全的保障，安全和发展要同步推进。”

2017年6月1日，我国的网络安全法正式实施。《网络安全法》第二十一条规定，网络运营者的网络安全等级保护义务：网络运营者有义务制定内部安全管理制度和操作规程、确定网络安全负责人；并应当采取防范病毒、攻击、入侵等危害网络安全行为的技术措施；网络运营者的日志留存时间必须不少于6个月；并有义务采取数据分类、重要数据备份和加密等措施。《网络安全法》规定对于网络运营者拒不履行安全的责任，明确处罚措施，包括暂停业务活动、严重的违法行为将导致停业整顿或吊销执照、处罚金额最高可至100万元、对于直接负责人进行罚款等。构成犯罪的会依法追究刑事责任。

本方案根据网络安全法和高校信息安全治理的相关建设要求，遵循“主动防御、综合防范、强化管理、安全第一”的原则，以保障高校关键信息系统持续、稳定、健壮运行为目标，通过某高校整体网络安全设计方案搭建完善的信息安全保障框架，包括防护、检测、处置、恢复的安全能力建设，建设“以风险管理为基础的安全技术支撑体系、安全运营管理体系”，为某高校提供全面的信息安全保障和安全运营支撑。

二　需求分析

2.1 边界防护

建设大型网络安全的一种方法就是把网络化分成单独的逻辑网络域，如组织内部的不同网络域，外部网络域等，每一个网络域由所定义的安全边界来保护，即分域保护。这种边界防护可通过在相连的两个网络域之间控制其域间访问和信息流来实现边界安全防护。

2.2 通信安全

该高校存在主校与分校跨地区的网络通信问题，分校需要访问主校的部分业务系统。跨地区的通信安全是一个重要的问题。使用运营商物理专线网络是一种从物理上保障跨地区通信安全的方式，但物理专线网络建设费用较高。不满足本次建设需求。这里需要使用一种既能保障通信安全，在通信过程中能实现加密、认证、防重放的安全通信，同时要以较低成本实现。

2.3 安全运维审计

按照网络安全等级保护相关制度要求，需要对安全管理员进行身份鉴别，只允许其通过特定的命令或操作界面进行安全管理操作，并进行审计。要求配备集中系统和设备管理功能的工具或平台，系统或平台需要有三权分立。设立安全管理员，安全管理员不能兼任其他岗位（如系统管理员、审计管理员、机房管理员等）。

2.4 数据库安全管理

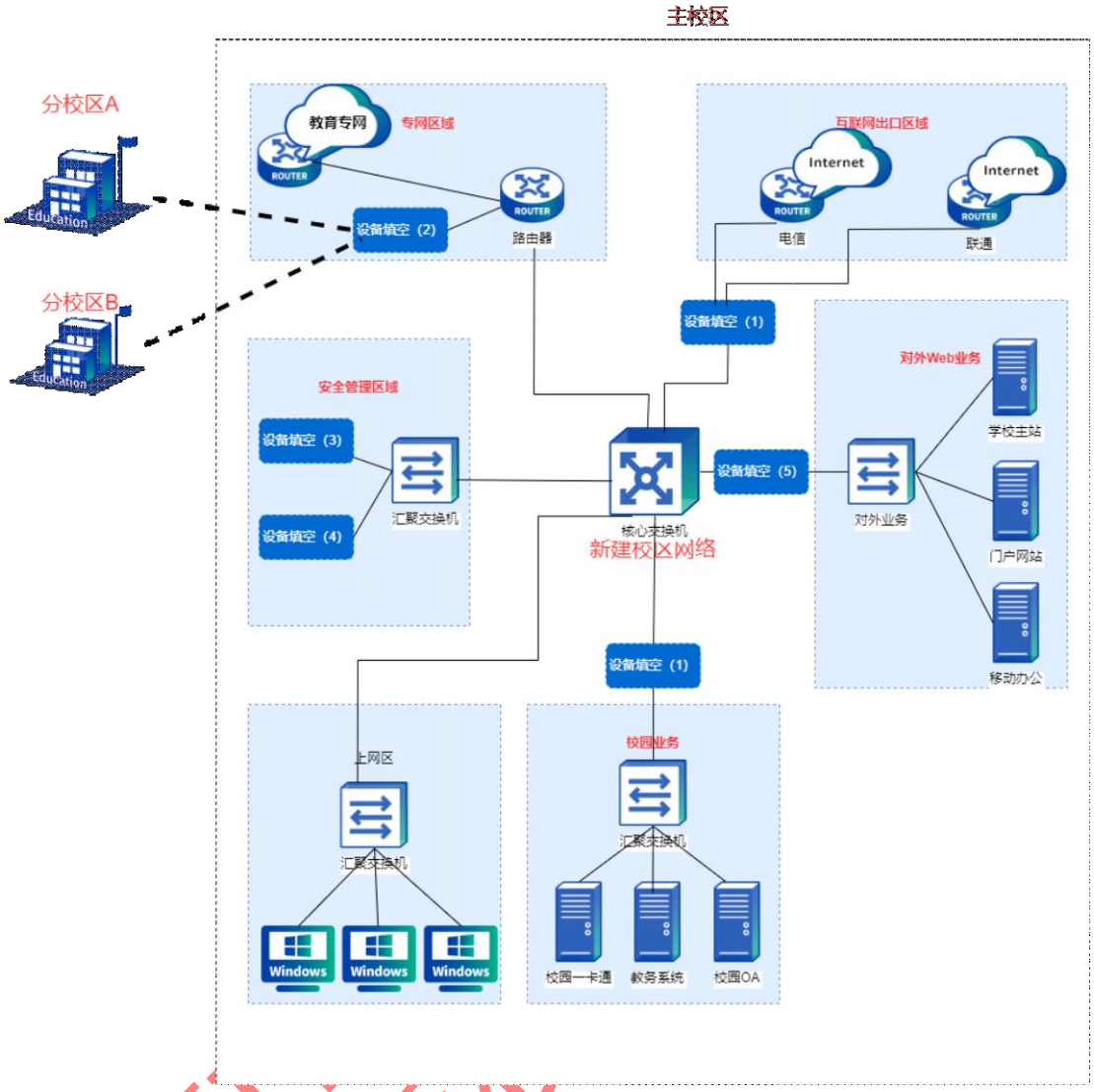
随着高校信息化的发展，网络规模和设备数量迅速扩大，面对日趋复杂的IT系统、安全问题，数据库管理带来较大潜在风险。数据库管理面临多种风险，如：内部人员违规操作、外包运维人员威胁、高权账号滥用、事故后无法追究责任、数据库操作不可控等。希望通过本次建设能加强对数据库使用的安全管理。

2.5 WEB防护

网站系统是学校的门户和互联网业务的窗口，具备较高的资产价值，极易成为黑客攻击目标，造成页面篡改、网站挂马、系统服务不可用、重要数据失泄密等一系列安全问题。如果不能及时发现和解决，就会造成多方面的严重后果。希望通过本次建设能提高WEB类业务系统的安全性。

上海市教育考试院 版权所有

三、拓扑设计



四、设备清单

4.1　VPN设备

VPN设备通常集成了标准IPSEC VPN模块和私有 VPN模块，既满足与其他设备按照国际标准对接，又可通过私有 VPN模块方便智能的建立虚拟专用网隧道。通过私有VPN模块建立的虚拟专用网络，不仅能实现跨区域办公满足业务扩展需要，并对数据在广域网上的传输做安全加密保障，还能加速访问的效果提高办公效率。

4.2　下一代防火墙设备

构建校园网各级边界的L2-7的完整安全防御体系；提高整体安全能力。实现网络访问控制和逻辑隔离，防止非授权访问；开启IPS模块，对异常流量进行检测和阻断；开启防病毒模块，实施网络层恶意代码的安全防护，防止恶意代码在关键网络节点的扩散。

4.3　数据库审计系统

数据库安全审计系统，可以对数据库访问操作进行记录，以及提供数据库安全防护功能。可以帮助组织强化数据库操作访问的规范性，完善数据库操作访问的管理，降低数据库资产安全风险，加固组织数据库资产的安全性与合规性。

4.4　运维堡垒机

运维堡垒机作为管理人员与管理专网之间的唯一通道，实现对运维人员的“身份认证、账户管理、控制权限、操作审计”等功能，支持多种字符终端协议、文件传输协议、图形终端协议、远程应用协议的安全监控与历史查询，具备全方位运维风险控制能力。

4.5 应用防火墙

应用防火墙是新一代安全产品，可提供完整L2-L7安全防御功能，不仅具备了传统三、四层防御功能的防火墙功能，同时能够对来自底层应用系统和来自应用层WEB应用系统的漏洞进行防护。应用防火墙能够有效防护OWASP组织提出的10大web安全威胁的主要攻击。如SQL注入、XSS、弱口令防护、HTTP异常防护等。

4.6 终端检测响应平台（EDR）

EDR一套终端安全解决方案，方案由轻量级的端点安全软件和管理平台软件共同组成。EDR的管理平台支持统一的终端资产管理、终端安全体检、终端合规检查，支持微隔离的访问控制策略统一管理，支持对安全事件的一键隔离处置，以及热点事件IOC的全网威胁定位，历史行为数据的溯源分析，远程协助取证调查分析。端点软件支持防病毒功能、入侵防御功能、防火墙隔离功能、数据信息采集上报、安全事件的一键处置等。

4.7 集中的日志管理系统

采集各类系统中的安全事件、用户访问记录、系统运行日志、系统运行状态、网络存取日志等各类信息，经过规范化、过滤、归并和分析等处理流程后，可以以统一格式的日志形式进行集中存储和管理。在此基础上，对日志进行实时的事件分析和审计分析、从而进行实时的事件监控和异常事件告警，最终实现对各类网络设备、安全设备、操作系统、服务器、数据库和其它应用进行全面的日志安全审计。

五、建设说明

作答说明：

在问题（1）（3）（5）(7)（9）填入前面第四节设备清单中的设备名称。

问题：

（1） 为了满足需求2.1，我们在设备拓扑图中“设备填空（1）”处，使用_____设备。（3分）

答：_____

（2） 使用上题“设备填空（1）”处的设备可以达到什么样的建设效果？（3分）

答：_____

（3） 为了满足需求2.2，我们在设备拓扑图中“设备填空（2）”处，使用_____设备。（3分）

答：_____

（4） 使用上题“设备填空（2）”处的设备可以达到什么样的建设效果？（3分）

答：_____

（5） 为了满足需求2.3，我们在设备拓扑图中“设备填空（3）”处，使用_____设备。（3分）

答：_____

（6） 使用上题“设备填空（3）”处的设备可以达到什么样的建设效果？（3分）

上海市教育考试院 版权所有

答：_____

（7） 为了满足需求2.4，我们在设备拓扑图中“设备填空（4）”处，使用_____设备。（3分）

答：_____

（8） 使用上题“设备填空（4）”处的设备可以达到什么样的建设效果？（3分）

答：_____

（9） 为了满足需求2.5，我们在设备拓扑图中“设备填空（5）”处，使用_____设备。（3分）

答：_____

（10） 使用上题“设备填空（5）”的设备可以达到什么样的建设效果？（3分）

答：_____

上海市教育考试院
版权所有